

Designing an Access Control System (3e)

Access Control and Identity Management, Third Edition - Lab 01

Student:

Christopher Phan

Email:

cphan@udallas.edu

Time on Task:

Progress:

100%

Report Generated: Thursday, June 2, 2022 at 2:56 PM

Guided Exercises

Part 1: Research Digital Identity Guidance

3. **Summarize** the process for establishing digital identity, shown in the figure below.

There are three steps in establishing a legitimate digital identity: identity proofing, identity authentication, and strengthening assertion through federal mediums. The figure below shows that the person that is asserting their digital identity can start as either a claimant or a applicant. Though they both become the subscriber, though each one has to go through multiple steps to do this. Each one has to do digital verification, such as a legit verifier, and they have to go through a credential service provider (CSP), authenticating the person is who they claim to be. Though the subscriber even after these two processes of verifying and authenticating must go to or from a relying party (RP) lastly, usually a federal entity, proving that the person asserting their digital identity is truly that person.

5. **Summarize** the requirements suggested by NIST for password-based authentication where the user is allowed to select his or her own passwords.

The requirements for a person using a self-appointed password must go through approved cryptography, methods that make the password much harder to crack and decipher, almost a randomized fashion that cannot be discovered through easy attempts. As well, the authenticator has a system in place that is able to detect if there is a compromise in the authenticator and warn users to not go any further. For when a user is going through a verifier, it must be through channels that are protected and secure, where any actions that the users takes cannot be tracked nor can be intercepted through a third party outside of the authentication. These requirements are even further accentuated if these actions are taken within a government agency.

Part 2: Design an Access Control System

Designing an Access Control System (3e)

1. All of your systems rely on passwords for one of their authentication factors. **Write** a password policy for the organization that is consistent with the best practices outlined in NIST 800-63b.

All passwords must be at least 15 characters long, as strength and composition is dependent on the length of a password, securing your system. Spaces must be included in passwords, creating greater complexity. Certain phrases will be blacklisted from being part of passwords due to ease of guessing. Also, there will be an RSA tokens giving out to all employees with randomized 6 PIN digits, creating a double password identification and authorization process. There will be implementation of secure hash storage as well as rate limiting for these processes too.

2. Your website permits different levels of access for the general public and for authenticated users. **Describe** the authentication process for customers accessing restricted areas of the website. **Identify** each authentication factor being used by type. **Answer** whether the approach qualifies as multifactor authentication.

There are three common authentication methods: something you know, something you have, or something you are. These can be translated into the common techniques implemented for customers: the knowledge factor, the possession factor, and the inheritance factor. The knowledge factor is the most ubiquitous method since its simply the user having two pieces of knowledge: their username and their chosen password. The possession factor is just a physical item or a third party verifier that has to be done to enter the website, these two are items that are acquired for the user are ways to prove that user is actually verified. Lastly the inheritance factor is something that is automatically part of the person, something physically have that cannot be taken away from the person, such as their fingerprint or their face, proving the identity of the user. All of these by themselves are not multifactor authentication, but if they are stacked upon each other, then yes it would be multifactor. Though usually for customers, only one of these would be required for them, which would be most likely the knowledge factor as they are not in a position that can compromise the company alone.

3. The human resources system requires stricter access controls than the website. **Describe** an authentication process for managers and HR staff accessing this system. **Identify** each authentication factor being used by type. **Answer** whether the approach qualifies as multifactor authentication.

Though for HR and management staff, they will HAVE to require multifactor authentication processes, meaning that the methods mentioned earlier must be stacked onto each other. The two processes that will be meshed together will be both the knowledge factor and the inheritance factor. As they will have to be absolutely secured due to their higher priority in the website, so they must have username and password, but as well as a way to identify themselves through absolutely proving they are who they say they are. Using a fingerprint scanner or a facial scanner will help prove without a doubt that the appropriate staff is within the staff, and their username and password will provide extra security on top. This approach is a multifactor process, and providing the true authentication for higher importance staff.

4. The manufacturing system also requires stricter access controls than the website, but the authentication system used must be broadly accessible to all users in the company. **Describe** an authentication process for employees accessing this system. **Identify** each authentication factor being used by type. **Answer** whether the approach qualifies as multifactor authentication.

Due to emphasis on accessibility, the possession factor is the chosen method for the manufacturing system. So a third party will simply identify any user who goes into the manufacturing system, allowable to everyone in the company. An example is the RSA tokens, as every time a user is trying to access the system, a randomized 6 PIN digit will be sent to the user, allowing ease of access but only allowing those who can go through the third party can use it. If the company does not want to rely on a third party, a physical ID card can be used, as when a user wants to go into the system, only a card swipe is necessary. This method would not be possible to any person except those in the company, but its easy to access for everyone within the company.

Challenge Exercise

1. Which authentication technique(s) are used by this system?

The authentication technique used by this system is simply a something you know, or a knowledge factor. I only need a username and password to access this textbook lab.

2. For each technique used, what is the category of the authentication factor?

The category this technique would be organized as a something you know.

3. Does this system qualify as multifactor authentication?

No, this system does not qualify as multifactor authentication.

4. If the system does not qualify as multifactor authentication, how could you modify it to qualify?

What could be modified, is adding a something you have, where it is required for the user to put in a randomized 6-8 PIN code that's sent to the user through a third party to access the labs.